

**Name:** IRAKOZE Jessica

**ID:** 26026

**Date:** 29/03/2026

## **Cybersecurity Assignment 1**

### **Main assets identified:**

- Student and staff records database (containing personally identifiable and potentially health-related information).
- A web-based appointment scheduling application, including its associated web server and backend database.
- Internal shared file repository (containing operational documents, schedules, and reports).
- Physical office infrastructure, including workstations, servers, network devices, and the office premises themselves.
- The system provides support in the form of backup storage and network infrastructure, which includes routers and firewalls.

### **Primary users:**

- Internal health office staff (full or role-based administrative access).
- Students and university community members (public users of the web appointment service).
- External visitors (limited physical access to the public-facing reception area).

### **Core services:**

- Public web-based appointment scheduling.
- Restricted internal access to student/staff records and shared files.
- Day-to-day record storage, retrieval, and administrative operations.

### **Most sensitive and mission-critical assets:**

The student and staff records represent the highest confidentiality risk, as unauthorized disclosure could result in privacy violations, legal exposure, and loss of public trust. The web-based appointment service is equally critical for operational continuity; any prolonged unavailability would directly disrupt service delivery to the university.

community. Shared files, while operationally important, are secondary in both their sensitivity and their impact on service continuity.

## **NOTE:**

The AUCA Community Health Office is a small, public-facing university unit responsible for storing sensitive student and staff records, operating a web-based appointment booking service for the wider university community, and maintaining internal shared-file access for authorized staff. In this resource-constrained environment, the office must balance daily operations with the protection of personal data that passes through its systems every day.

The most critical assets are the student and staff records database, which holds personally identifiable and potentially health-related information, and the web-based appointment service. A breach of the records would expose the university to serious privacy violations, legal penalties, and lasting loss of trust. The appointment platform is equally vital for availability; any extended downtime would halt core health services and disrupt hundreds of users. Internal shared files, while operationally useful, are secondary in sensitivity.

The strongest controls provide a solid baseline. Physical keycard access combined with a mandatory visitor sign-in log effectively limits who can enter the office and approach workstations. The network firewall, configured to allow only standard web traffic (ports 80 and 443) with a default-deny policy, significantly reduces the external attack surface on the appointment service. File-system access control lists restrict read/write rights to the “HealthOfficeStaff” group only, while automated nightly encrypted backups to both on-site and off-site storage offer reliable data recovery. Together, these measures deliver thoughtful basic protection for confidentiality and availability in a small-office setting.

However, several weak areas leave the organization exposed. The organization's defense in depth is incomplete: while the physical and network perimeters receive reasonable coverage, the host and application layers lack sufficient protection. The web appointment service has no web-application firewall or input validation, making it vulnerable to common web attacks. The password policy relies on single-factor authentication, and there is no file-access auditing or centralized logging, allowing insider threats or successful breaches to go undetected for weeks. Most critically, the office has no documented incident response plan, no defined roles, and has never tested backups through a restore drill. In a real incident these gaps would delay detection, slow

containment, and risk permanent data loss—especially dangerous given the sensitive nature of health-related records.

**Top three recommendations**, prioritized for maximum impact with minimal cost and effort:

1. Enable multi-factor authentication on all staff accounts and activate file-access auditing. This immediately strengthens credential security and provides visibility as to who accesses records.
2. Deploy a basic web-application firewall in front of the appointment service and apply at-rest encryption to the live database. These steps close the most obvious application and data-layer exposures.
3. Draft a short incident response plan with clear roles and conduct a one-hour tabletop exercise to test the backup restoration process. This builds organizational readiness and turns existing backups into a proven recovery capability.